Evidence to action.

OpenFix 0.2 • A local security-case workflow
Markus Weldon • Repository walkthrough and implementation reference

01

PRESERVE

What security tools already know

02

INVESTIGATE

The gaps that change a decision

03

VERIFY

The exact change and its behavior

What AI adds to a mature security workflow

Keep established DevSecOps controls; add adaptive investigation and proposals behind evidence gates.

MATURE DEVSECOPS

Established controls

Scanners, tests, CI policy, ownership and release controls remain the foundation.

POTENTIAL AI CONTRIBUTION

Adaptive investigation

Reason across code and context. Propose focused checks and bounded changes.

OPENFIX ROLE

Independent evidence gates

Preserve provenance, expose gaps, verify exact changes and record human decisions.

Many observations, one persistent case

Implemented adapters normalize source exports while retaining their original evidence.

SARIF	Rules, locations, tool identity and result properties
GHAS + Snyk	Code-scanning alerts and dependency findings
Codex Security JSON	Scan findings, manifest, coverage and deferred surfaces
Case correlation	Link matching observations; retain each source record
Durable local state	JSON records, atomic writes, exclusive lock and audit chain

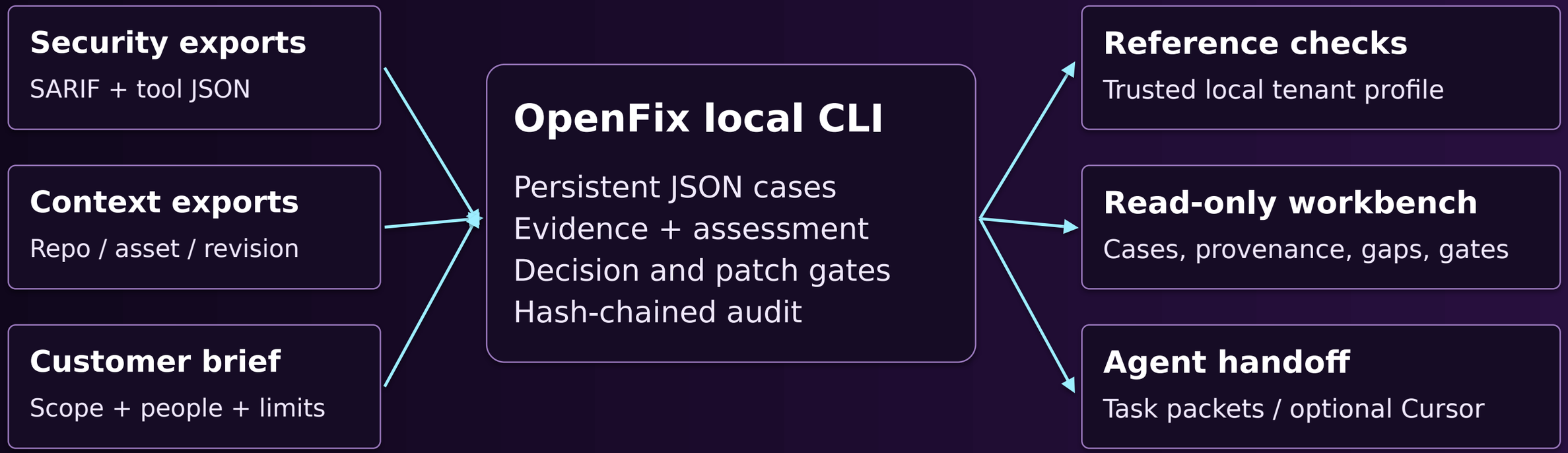
Reuse evidence and preserve its authority

The evidence plan says what to reuse, refresh, collect or resolve.

Subject	Repository, revision and asset must match the case
Freshness	Use collection time / expiry; flag stale or unknown dates
Provenance	Keep producer, authority, source reference and artifact digest
Conflicts	Retain competing current claims; ask for a decision
Validation	Producer verdicts stay assertions until explicitly reviewed

The implemented local architecture

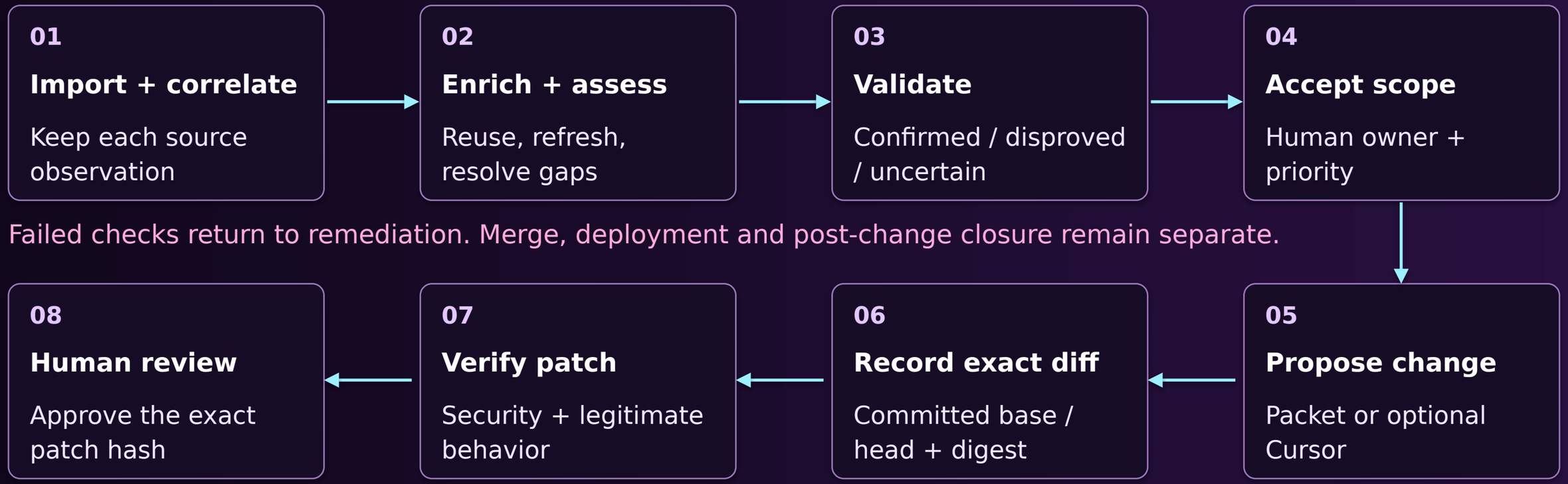
One CLI owns durable cases; adapters and execution profiles have explicit boundaries.



Local processes and actor labels are implemented. Isolated workers and enterprise authentication are not.

Each case carries evidence and decisions

Implemented local stages preserve evidence and require explicit decisions.



Failed checks return to remediation. Merge, deployment and post-change closure remain separate.

A repository map for the conversation

Follow evidence from source imports through assessment, decisions and executable invariants.

Import	src/workflow/import.mjs	Keep reports and producer evidence.
Assess	src/workflow/enrich.mjs	Check subject, freshness and conflicts.
Act	src/workflow/operations.mjs	Accept, verify and review exact changes.
Enforce	src/lifecycle/workflow.mjs	Enforce lifecycle and patch identity.
Prove	tests/workflow.test.mjs	Test stale context and broken fixes.

Read the example as four distinct decisions

Synthetic source fixtures and local checks exercise supported, disproved and uncertain paths.

Vulnerable lookup	Runtime confirmed → accepted → verified patch → reviewed
Protected lookup	Cross-tenant access blocked → disproved → dismissed
Dependency issue	No installed validation profile → inconclusive
Cloud context	Conflicting service owners → resolve the conflict

Code and tests separate a useful finding, a protected path, missing proof and conflicting context.

A false fix reveals the verification contract

Read the deny-all and tenant-scoped changes against security and legitimate-behavior assertions.

DELIBERATELY BAD FIX

Deny all requests

Security check: passed
Legitimate behavior: failed

Verification fails.
Human approval is blocked.

CORRECTED COMMITTED DIFF

Enforce tenant ownership

Security check: passed
Legitimate behavior: passed

Verification passes.
Reviewer approves the hash.

Approval belongs to an exact change

A plausible fix description is insufficient evidence for publication.

Accepted scope	Owner, priority, rationale and context recorded
Artifact identity	Real git diff: committed base + head + SHA-256
Independent check	Verifier label differs from the patch author
Review gate	Passing security + regression checks, exact hash
After review	Normal publication, merge and deployment controls

Give agents a bounded security case

Implemented handoffs preserve evidence, scope and expected outputs.

DEFAULT

Portable task packet

Export case.json and instructions with provenance, gaps and permitted actions.

NATIVE GUIDANCE

.agents skills

Use the approved security workflow; treat findings and tool output as untrusted data.

OPTIONAL EXECUTOR

Cursor dispatch

Actor + execution + draft-PR authorization. Verify and review the returned patch.

Use native security capabilities

OpenFix complements security capabilities with customer evidence and change decisions.

Defense Factory	Continuous operating model and reference architecture
Daybreak	Broader governed cyber-defense capability stack
Codex Security	Native code investigation, evidence, validation and fixes
Promptfoo	AI application and agent adversarial evaluation
OpenFix 0.2	Local evidence reuse, customer context and exact-change gates

What remains for production

Keep the implemented controls and remaining boundaries visible.

IMPLEMENTED

Inspectable local controls

Persistent cases, exact joins, freshness checks, artifact binding, named actors and audit history.

STILL REQUIRED

Production boundaries

Authenticated identities, isolated workers, egress and secret controls, durable service storage.

STILL TO PROVE

Real integrations + scale

Live connectors, model behavior, broader validators, customer-scale evals and operational recovery.

Lead a customer working session

The provided scenario sets the scope. No presentation or advance work is required.

01	**Discover the problem**	Outcome, people, bottleneck, constraints
02	**Map the evidence**	Existing tools, assets, revisions and trusted context
03	**Choose a useful AI step**	Native capability, integration gap and authority
04	**Plan proof and rollout**	Pilot, failure cases, owners and decision gate
05	**Adapt in real time**	Restate changed assumptions and revise the plan

A pilot should lead to an operating decision

One service, one issue class and one accountable reviewer; measure the baseline first.

BASELINE

Know today’s work

Investigation effort, review time, accepted outcomes, delay and existing controls.

EVALUATE

Include failure paths

Valid, disproved, stale, conflicting and missing proof. Bad fixes, cost and latency.

DECIDE

Expand, revise or stop

Agree evidence, owners, milestones and limits. Expand one scope dimension at a time.

Sources and evidence boundaries

Public workflow references plus an inspectable, reproducible local implementation.

Defense Factory: operating model
openai.com/the-defense-factory/

Daybreak: broader security stack
openai.com/daybreak/

Codex Security: finding and fix evidence
learn.chatgpt.com/docs/security/plugin/fix-findings

Codex Security: access and Cloud billing
learn.chatgpt.com/docs/security/faq

Promptfoo: agent adversarial evaluation
promptfoo.dev/docs/red-team/agents/